

NEURONEX AI / SEGURANÇA, PRIVACIDADE E GOVERNANÇA

Política de Gestão de Chaves de API e Secrets

Regras para criação, armazenamento, uso, rotação, revogação e evidência de credenciais técnicas.

Código	NRX-SEC-KEY-001	Versão	1.0
Responsável	Jhonatan Gasperi de Oliveira	Vigência	01 de julho de 2026
Classificação	Uso controlado	Próxima revisão	01 de julho de 2027

VIGENTE

Documento aprovado para uso interno e apresentação como evidência institucional, sujeito às revisões e controles descritos.

1. Objetivo

Impedir que chaves de API, tokens, senhas, service roles e secrets sejam expostos a usuários, código público, logs, imagens, banco acessível pelo navegador ou ambientes inadequados.

2. Escopo

Abrange credenciais do Asaas, Supabase, Vercel, Cloudflare, R2, GitHub, Google, provedores de IA, e-mail, webhooks e qualquer integração técnica da NeuroNex AI.

3. Classificação

Classe	Tratamento
Público controlado	Identificadores que podem existir no frontend, como URL pública e chave anon do Supabase, desde que não concedam privilégio administrativo.
Confidencial	Tokens de webhook, chaves de integração e credenciais técnicas com acesso limitado.
Crítico	Service role, chave mestra de criptografia, credencial Asaas de produção, tokens administrativos e secrets de assinatura.

4. Regras obrigatórias

- Nunca armazenar credenciais reais em repositório, migration, documentação pública, chat, ticket, print ou variável exposta ao navegador.
- Secrets de produção devem permanecer em armazenamentos server-side do provedor ou cofre aprovado.
- Ambientes de desenvolvimento, preview, sandbox e produção devem possuir credenciais distintas.
- Chaves mestras de criptografia devem permanecer fora do banco de dados e nunca aparecer em logs.
- O acesso a secrets deve ser individual, mínimo, revisado e protegido por MFA.
- Toda rotação, revogação ou exceção deve ser registrada sem registrar o valor secreto.



5. Armazenamento permitido

- Supabase Edge Function Secrets e Vault, conforme a finalidade e o modelo de acesso.
- Vercel Environment Variables separadas por ambiente.
- Cloudflare Secrets e configurações equivalentes para Workers/R2.
- Console oficial do fornecedor, quando a credencial não precisa sair do serviço.
- Estrutura privada e criptografada no banco somente quando necessária ao funcionamento, sem grants para anon ou authenticated.

6. Ciclo de vida

1. Gerar a credencial no ambiente correto e registrar nome lógico, finalidade, proprietário e data.
2. Armazenar no cofre apropriado e conceder acesso somente ao runtime ou administrador necessário.
3. Testar sem imprimir o valor e verificar que o frontend não consegue recuperá-lo.
4. Revisar a necessidade trimestralmente e após incidentes ou mudanças de equipe/fornecedor.
5. Rotacionar por suspeita de exposição, desligamento, alteração material, solicitação do fornecedor ou calendário aprovado.
6. Revogar a credencial antiga e validar logs, integrações e ausência de chamadas não autorizadas.

7. Credenciais Asaas

Credenciais de subcontas Asaas não devem permanecer em coluna exposta do schema público. O desenho-alvo utiliza armazenamento privado, criptografia de aplicação AES-GCM e chave mestra exclusivamente server-side. A migração deve ocorrer de forma controlada, sem impressão do valor, seguida de verificação e rotação da credencial.

8. Resposta à suspeita de vazamento

7. Tratar o evento como incidente e limitar imediatamente o uso da credencial.
8. Revogar ou rotacionar no fornecedor.
9. Atualizar o secret store e testar as integrações afetadas.
10. Revisar histórico Git, logs e artefatos para determinar exposição.
11. Registrar causa, impacto, ações corretivas e prevenção de recorrência.

9. Evidências

- Capturas com nomes de secrets e valores mascarados.
- Registro de rotação com ambiente, data, responsável e motivo.
- Resultados de Gitleaks e checks de CI.
- Matriz de acesso a cofres e contas administrativas.
- Teste que demonstre que o navegador não recebe a credencial.

10. Exceções

Exceções devem ser temporárias, aprovadas, justificadas e acompanhadas de prazo de remoção e controle compensatório. Não é permitida exceção que autorize publicação de secret real em repositório, frontend ou documento de evidência.



Aprovação

Aprovo este documento e determino sua aplicação a partir da data de vigência indicada.

Jhonatan Gasperi de Oliveira

Responsável e aprovador institucional

Assinatura digital: _____ Data: 01/07/2026



Documento assinado digitalmente
JHONATAN GASPERI DE OLIVEIRA
Data: 01/07/2026 22:53:25-0300
Verifique em <https://validar.iti.gov.br>